

Política de Seguridad de la Información

ELABORO	REVISO	APROBO
Nombre: Cargo:	Nombre Cargo:	Directorio de XXXX.

Contenido

1. Alcance	3
2. Seguridad de la Información	3
3. Política de Seguridad de la Información.....	3
4. Seguridad Frente al Acceso por Parte de Terceros	4
5. Clasificación y Control de Activos	6
6. Seguridad del Personal.....	7
7. Seguridad Física y Ambiental	8
8. Gestión de Comunicaciones y Operaciones.....	11
9. Control de Accesos.....	13
10. Desarrollo y Mantenimiento de Sistemas	19
11. Administración de la Continuidad de las Actividades de la Organización	22
12. Cumplimiento.....	23

1. Alcance

La presente Política de Seguridad de la Información emerge como instrumento de concientización a sus miembros de la importancia y sensibilidad de la información, permitiéndoles cumplir de forma segura la misión de negocio.

Esta Política ha sido elaborada a fin de dar cumplimiento a las directivas de la Organización y a las disposiciones contractuales y legales vigentes.

2. Seguridad de la Información

La seguridad de la información se entiende como la preservación de las siguientes características:

- **Integridad:** Proteger y salvaguardar el estado completo de los activos, considerándose como activo a todo aquello que posea valor para la Organización, ya sean materiales o intangibles.
- **Confidencialidad:** Asegurar que la información sea accesible sólo por las personas autorizadas.
- **Disponibilidad:** Asegurar el acceso a la información, en tiempo y forma.
- **Legalidad:** Cumplir con las leyes, normas, reglamentaciones y disposiciones vigentes en materia de seguridad de la información.
- **Auditabilidad:** Todos los eventos de un sistema deben poder ser registrados para su control posterior.

3. Política de Seguridad de la Información

La información es un recurso que, como el resto de los activos, tiene valor para la organización y por consiguiente debe ser debidamente protegida.

La Política de Seguridad de la Información protege a la misma de una amplia gama de amenazas, a fin de garantizar la continuidad de los sistemas de información, minimizar los riesgos de daño y asegurar el eficiente cumplimiento de los objetivos de la Organización.

Es importante que los principios de la Política de Seguridad sean parte de la cultura Organizacional. Para esto, se debe asegurar un compromiso manifiesto de las máximas autoridades de la Organización para la difusión, consolidación y cumplimiento de la presente Política.

Objetivo

Proteger los recursos de información de la Organización y la tecnología utilizada para su procesamiento, frente a amenazas, internas o externas, deliberadas o accidentales, con el fin de asegurar el cumplimiento de la confidencialidad, integridad, disponibilidad, Auditabilidad y legalidad de la información.

Alcance

Esta Política se aplica en todo el ámbito de la Organización, a sus recursos y a la totalidad de los procesos, ya sean internos o externos vinculados a la misma a través de contratos o acuerdos con terceros.

Responsabilidad

Todos los Directivos son responsables de la comunicación de esta Política de Seguridad de la Información dentro de sus áreas, así como del reporte inmediato en caso de tomar conocimiento de cualquier desvío a la misma por parte de su equipo de trabajo a **Seguridad de la Información**.

Seguridad de la Información procederá a:

- Supervisar el cumplimiento de la presente Política de Seguridad de la Información.
- Tomar conocimiento y supervisar la investigación y monitoreo de los incidentes relativos a la seguridad.
- Evaluar y coordinar la implementación de controles específicos de seguridad de la información para nuevos sistemas o servicios.
- Promover la difusión y apoyo a la seguridad de la información dentro de la Organización.

El **Directorio de la Organización** será el responsable de proponer para su aprobación la presente Política de Seguridad de la Información y de coordinar las acciones para impulsar la implementación y cumplimiento de la misma.

Toda la información utilizada por La empresa debe poseer un **Propietario**. Los **Propietarios de la Información** son los responsables de clasificar la misma de acuerdo con su grado de sensibilidad y criticidad y de definir qué usuarios deberán tener permisos de acceso a la información de acuerdo a sus funciones y competencia.

Recursos Humanos cumplirá la función de notificar a todo el personal que ingresa de sus obligaciones respecto del cumplimiento de la Política de Seguridad de la Información.

Sistemas cumplirá la función de cubrir los requerimientos de seguridad informática establecidos para la operación y administración de los sistemas y recursos de tecnología de la Organización. Por otra parte, tendrá la función de efectuar las tareas de desarrollo y mantenimiento de sistemas, siguiendo una metodología que contemple la inclusión de medidas de seguridad en los sistemas.

Legales verificará el cumplimiento de la presente Política en la gestión de todos los contratos, acuerdos u otra documentación de la Organización con sus empleados y con terceros. Asimismo, asesorará en materia legal a la Organización en lo que se refiere a la seguridad de la información.

Los **usuarios de la información y de los sistemas** utilizados para su procesamiento son responsables de conocer, dar a conocer, cumplir y hacer cumplir la Política de Seguridad de la Información vigente.

Auditoría Interna es responsable de practicar auditorías periódicas sobre los sistemas y actividades vinculadas con la tecnología de información, debiendo informar sobre el cumplimiento de las especificaciones y medidas de seguridad de la información establecidas por esta Política y por las normas y procedimientos que de ella surjan.

4. Seguridad Frente al Acceso por Parte de Terceros

Debe tenerse en cuenta que ciertas actividades de la Organización pueden requerir que terceros accedan a información interna, o bien puede ser necesaria la tercerización de ciertas funciones relacionadas con el procesamiento de la información. En estos casos se considerará que la información puede ponerse en riesgo si el acceso de dichos terceros se produce en el marco de una inadecuada administración de la seguridad, por lo que se establecerán las medidas adecuadas para la protección de la información.

Objetivo

Garantizar la aplicación de medidas de seguridad adecuadas en los accesos de terceros a la información de la Organización.

Alcance

Esta Política se aplica a todos los recursos de la Organización y a todas sus relaciones con terceros que impliquen el acceso a sus datos, recursos y/o a la administración y control de sus sistemas de información.

Responsabilidad

Seguridad de la Información junto con los **Propietarios de la Información**, analizarán el riesgo de los accesos de terceros a la información de la Organización y verificará la aplicación de las medidas de seguridad necesarias para la protección de esta.

4.1. Identificación de Riesgos de Acceso de Terceras Partes

Cuando exista la necesidad de otorgar acceso a terceras partes a información de la Organización, **Seguridad de la Información** y el **Propietario de la Información** llevarán a cabo y documentarán una evaluación de riesgos para identificar los requerimientos de controles específicos, teniendo en cuenta, entre otros aspectos:

- El tipo de acceso requerido (físico/lógico y a qué recurso).
- Los motivos para los cuales se solicita el acceso.
- La incidencia de este acceso en la seguridad de la información.

En todos los contratos se establecerán los requerimientos de seguridad y compromisos de confidencialidad aplicables al caso, restringiendo al mínimo necesario, los permisos a otorgar.

4.2. Requerimientos de Seguridad en Contratos o Acuerdos con Terceros

Se revisarán los contratos o acuerdos existentes o que se efectúen con terceros, teniendo en cuenta la necesidad de aplicar los siguientes controles:

- Cumplimiento de la Política de seguridad de la información de la Organización.
- Proceso claro y detallado de administración de cambios.
- Controles que garanticen protección contra software malicioso.
- Derecho a realizar auditorías por parte de la empresa.
- Acuerdo de confidencialidad.
- Acuerdo de nivel de servicio.
- Acuerdo de propiedad de la información a favor de la empresa.
- Acceso a los registros de eventos de seguridad y transaccionales.
- Cifrado de extremo a extremo en toda transmisión de datos.
- Cumplimiento de los requisitos establecidos en la ley 25.326 de Protección de datos personales.
- Entrega de los programas fuentes al finalizar el proyecto en el caso de un desarrollo.

5. Clasificación y Control de Activos

La Organización debe tener un acabado conocimiento sobre los activos que posee como parte importante de la administración de riesgos.

Los activos de información deben ser clasificados de acuerdo con la sensibilidad y criticidad de la información que contienen o bien de acuerdo a la funcionalidad que cumplen con el objeto de señalar cómo ha de ser tratada y protegida dicha información.

Objetivo

Garantizar que los activos de información reciban un apropiado nivel de protección.

Alcance

Esta Política se aplica a toda la información administrada en la Organización, cualquiera sea el soporte en que se encuentre.

Responsabilidad

Los **Propietarios de la Información** son los encargados de clasificarla de acuerdo con su grado de sensibilidad y criticidad.

Seguridad de la Información es el encargado de asegurar que los lineamientos para la utilización de los recursos de la tecnología de información contemplen los requerimientos de seguridad establecidos según la criticidad de la información que procesan.

5.1. Inventario de activos

Se identificarán los activos importantes asociados a cada sistema de información, sus respectivos propietarios y su ubicación, para luego elaborar un inventario con dicha información.

El mismo será actualizado ante cualquier modificación.

El encargado de elaborar el inventario y mantenerlo actualizado es el **Responsable de cada sector** de la Organización.

5.2. Clasificación de la información

Para clasificar un Activo de Información, se evaluarán las tres características de la información en las cuales se basa la seguridad: **Confidencialidad, Integridad y Disponibilidad**.

A continuación, se establece el criterio de clasificación de la información en función a cada una de las mencionadas características:

CONFIDENCIALIDAD

0	Información que puede ser conocida y utilizada sin autorización por cualquier persona, sea empleado de la Organización o no
1	Información que puede ser conocida y utilizada por todos los empleados de la Organización y algunas entidades externas debidamente autorizadas, y cuya divulgación o uso no autorizados podría ocasionar riesgos o pérdidas leves para la Organización.
2	Información que sólo puede ser conocida y utilizada por un grupo de empleados, que la

	necesiten para realizar su trabajo, y cuya divulgación o uso no autorizados podría ocasionar pérdidas significativas a la Organización.
3	Información que sólo puede ser conocida y utilizada por un grupo muy reducido de empleados, generalmente de la alta dirección de la Organización, y cuya divulgación o uso no autorizados podría ocasionar pérdidas graves a la misma.

INTEGRIDAD

0	Información cuya modificación no autorizada puede repararse fácilmente, o no afecta la operatoria de la Organización.
1	Información cuya modificación no autorizada puede repararse aunque podría ocasionar pérdidas leves para la Organización.
2	Información cuya modificación no autorizada es de difícil reparación y podría ocasionar pérdidas significativas para la Organización.
3	Información cuya modificación no autorizada no podría repararse, ocasionando pérdidas graves a la Organización.

DISPONIBILIDAD

0	Información cuya inaccesibilidad no afecta la operatoria de la Organización.
1	Información cuya inaccesibilidad permanente durante una hora podría ocasionar pérdidas significativas para la Organización.
2	Información cuya inaccesibilidad permanente durante un día podría ocasionar pérdidas significativas a la Organización.
3	Información cuya inaccesibilidad permanente durante una semana podría ocasionar pérdidas significativas a la Organización.

Al referirse a pérdidas, se contemplan aquellas medibles (materiales) y no medibles (imagen, valor estratégico de la información, obligaciones contractuales o públicas, disposiciones legales, etc.).

Se asignará a la información un valor por cada uno de estos criterios. Luego, se clasificará la información en una de las siguientes categorías:

CRITICIDAD BAJA	Ninguno de los valores asignados supera el 1.
CRITICIDAD MEDIA	Alguno de los valores asignados es 2.
CRITICIDAD ALTA	Alguno de los valores asignados es 3.

En adelante se mencionará como “*Información Clasificada*” a aquella que se encuadre en los niveles 1, 2 o 3 de Confidencialidad.

6. Seguridad del Personal

Es fundamental educar e informar al personal desde su ingreso y en forma continua, acerca de las medidas de seguridad que afectan al desarrollo de sus funciones y de las expectativas depositadas en ellos en materia de seguridad y asuntos de confidencialidad.

Objetivo

Reducir los riesgos de error humano, uso inadecuado de instalaciones y recursos y manejo no autorizado de la información.

Garantizar que los usuarios se encuentren capacitados para respaldar la Política de Seguridad de la Organización en el transcurso de sus tareas normales.

Alcance

Esta Política se aplica a todo el personal de la Organización y al personal externo que efectúe tareas dentro del ámbito de esta.

Responsabilidad

Recursos Humanos informará a todo el personal que ingresa de sus obligaciones respecto del cumplimiento de la Política de Seguridad de la Información.

Seguridad de la Información tiene a cargo el seguimiento, documentación y análisis de los incidentes de seguridad reportados.

Todo el personal de la Organización es responsable del reporte de debilidades e incidentes de seguridad que oportunamente se detecten.

6.1. Capacitación del Usuario

Todos los empleados de la Organización y, cuando sea pertinente, los usuarios externos y los terceros que desempeñen funciones en la misma recibirán una adecuada capacitación y actualización periódica en materia de la política, normas y procedimientos de la Organización

El personal que ingrese a la Organización recibirá el material, indicándosele el comportamiento esperado en lo que respecta a la seguridad de la información, antes de serle otorgados los privilegios de acceso a los sistemas que correspondan.

6.2. Respuesta a Incidentes y Anomalías en Materia de Seguridad

Se establecerá un procedimiento formal de comunicación y de respuesta a incidentes, indicando la acción que ha de emprenderse al recibir un informe sobre incidentes.

Dicho procedimiento deberá contemplar que, ante la detección de un supuesto incidente o violación de la seguridad, **Seguridad de la Información** será informado tan pronto como se haya tomado conocimiento. Este indicará los recursos necesarios para la investigación y resolución del incidente, y se encargará de su monitoreo.

7. Seguridad Física y Ambiental

La seguridad física y ambiental brinda el marco para minimizar los riesgos de daños e interferencias a la información y a las operaciones de la Organización. Asimismo, pretende evitar el riesgo de accesos físicos no autorizados, mediante el establecimiento de perímetros de seguridad.

El establecimiento de perímetros de seguridad y áreas protegidas facilita la implementación de controles tendientes a proteger las instalaciones de procesamiento de información de la Organización, de accesos físicos no autorizados.

El control de los factores ambientales permite garantizar el correcto funcionamiento de los equipos de procesamiento y minimizar las interrupciones de servicio.

Gran cantidad de información manejada en las oficinas se encuentra almacenada en papel, por lo que es necesario establecer pautas de seguridad para la conservación de dicha documentación.

Objetivo

Prevenir e impedir accesos no autorizados, daños e interferencia a las sedes, instalaciones e información de la Organización.

Proteger el equipamiento de procesamiento de información de la Organización ubicándolo en áreas protegidas y resguardadas por un perímetro de seguridad definido, con medidas de seguridad y controles de acceso apropiados.

Controlar los factores ambientales que podrían perjudicar el correcto funcionamiento del equipamiento informático que alberga la información de la Organización.

Implementar medidas para proteger la información manejada por el personal, en el marco de sus labores habituales.

Alcance

Esta Política se aplica a todos los recursos físicos relativos a los sistemas de información de la Organización: instalaciones, equipamiento, cableado, expedientes, medios de almacenamiento, etc.

Responsabilidad

Seguridad de la Información definirá junto con **Sistemas** y los **Propietarios de Información**, según corresponda, las medidas de seguridad física y ambiental para el resguardo de los activos críticos, en función a un análisis de riesgos, y controlará su implementación.

Sistemas coordinará la implementación de las medidas de seguridad definidas para áreas protegidas y controlará el mantenimiento del equipamiento informático.

Cada Sector definirán los niveles de acceso físico del personal de la Organización a las áreas restringidas bajo su responsabilidad.

Todo el personal de la Organización es responsable del cumplimiento de la política de pantallas y escritorios limpios, para la protección de la información relativa al trabajo diario en las oficinas.

7.1. Perímetro de Seguridad Física

La protección física se llevará a cabo mediante la creación de diversas barreras o medidas de control físicas alrededor de las sedes de la Organización y de las instalaciones de procesamiento de información.

La Organización utilizará perímetros de seguridad para proteger las áreas que contienen instalaciones de procesamiento de información, de suministro de energía eléctrica, de aire acondicionado, y cualquier otra área considerada crítica para el correcto funcionamiento de los sistemas de información. El nivel de seguridad del perímetro será definido por **Sistemas** con el asesoramiento de **Seguridad de la Información**, de acuerdo a la evaluación de riesgos efectuada.

7.2. Controles de Acceso Físico

Las áreas protegidas se resguardarán mediante el empleo de controles de acceso físico, dichos controles tendrán, por lo menos, las siguientes características:

- Supervisar o inspeccionar a los visitantes a áreas protegidas y registrar la fecha y horario de su ingreso y egreso.

- Controlar y limitar el acceso a la información clasificada y a las instalaciones de procesamiento de información, exclusivamente a las personas autorizadas. Se mantendrá un registro protegido para permitir auditar todos los accesos.
- Revisar periódicamente los derechos de acceso a las áreas protegidas.

7.3. Ubicación y Protección del Equipamiento y Copias de Seguridad

El equipamiento y las copias de seguridad serán ubicados y protegidos de tal manera que se reduzcan los riesgos ocasionados por amenazas y peligros ambientales, y las oportunidades de acceso no autorizado.

7.4. Suministros de Energía

El equipamiento estará protegido con respecto a las posibles fallas en el suministro de energía u otras anomalías eléctricas para asegurar la continuidad del suministro de energía.

7.5. Seguridad del Cableado

El cableado de energía eléctrica y de comunicaciones que transporta datos o brinda apoyo a los servicios de información estará protegido contra interceptación o daño.

7.6. Mantenimiento de Equipos

Se realizará el mantenimiento del equipamiento para asegurar su disponibilidad e integridad permanentes.

Cuando sea necesario el retiro de equipamiento de la sede de la Organización para su mantenimiento se debe registrar su salida y eliminar la información confidencial que contenga realizándose previamente las respectivas copias de resguardo.

7.7. Desafectación Segura de los Equipos.

La información puede verse comprometida por una desafectación o una reutilización descuidada del equipamiento. Los medios de almacenamiento conteniendo material sensible serán físicamente destruidos o sobrescritos en forma segura en lugar de utilizar las funciones de borrado estándar, según corresponda.

7.8. Políticas de Escritorios y Pantallas Limpias.

Se adoptará una política de escritorios limpios para proteger documentos en papel y dispositivos de almacenamiento removibles y una política de pantallas limpias en las instalaciones de procesamiento de información, a fin de reducir los riesgos de acceso no autorizado, pérdida y daño de la información.

La información que se deja sobre los escritorios también está expuesta a sufrir daños o destrozos en caso de producirse un desastre como incendio, inundación o explosión.

Se deben aplicar los siguientes lineamientos.

- Cuando corresponda, los documentos en papel y los medios informáticos deben ser almacenados bajo llave. Especialmente fuera del horario de trabajo.

- La información sensible o confidencial, una vez impresa, debe ser retirada de la impresora inmediatamente.
- Cerrar las aplicaciones y/o bloquear la pantalla cuando se aleje de su escritorio.
- No dejar medios de almacenamiento removibles como Pen Drives conectados a los equipos.
- Apagar el equipo al alejarse por períodos prolongados de tiempo.
- No escribir las contraseñas en notas autoadhesivas ni tratar de esconderlas en la oficina.
- Borrar pizarrones.

8. Gestión de Comunicaciones y Operaciones

Es conveniente separar los ambientes de desarrollo, prueba y operaciones de los sistemas de la organización, estableciendo procedimientos que aseguren la calidad de los procesos que se implementen en el ámbito operativo, a fin de minimizar los riesgos de incidentes producidos por la manipulación de información operativa.

Objetivo

Garantizar el funcionamiento correcto y seguro de las instalaciones de procesamiento de la información y comunicaciones.

Establecer responsabilidades y procedimientos para su gestión y operación, incluyendo instrucciones operativas y separación de funciones.

Alcance

Todas las instalaciones de procesamiento y transmisión de información de la Organización.

Responsabilidad

Seguridad de la Información tendrá a su cargo:

- Establecer criterios de aprobación para nuevos sistemas de información en materia de seguridad de la información.
- Definir procedimientos para el manejo de incidentes de seguridad.
- Definir y documentar una norma clara con respecto al uso del correo electrónico e Internet.
- Definir y documentar controles para la detección y prevención del acceso no autorizado, la protección contra software malicioso y para garantizar la seguridad de los datos y los servicios conectados en las redes de la Organización.
- Desarrollar procedimientos adecuados de concientización de usuarios en materia de seguridad
- Verificar el cumplimiento de las normas, procedimientos y controles establecidos.

Sistemas tendrá a su cargo lo siguiente:

- Controlar la existencia de documentación actualizada relacionada con los procedimientos de comunicaciones y operaciones.
- Evaluar el posible impacto operativo de los cambios previstos a sistemas y equipamiento y verificar su correcta implementación, asignando responsabilidades.
- Administrar los medios técnicos necesarios para permitir la segregación de los ambientes de procesamiento.
- Controlar la realización de las copias de resguardo de información, así como la prueba periódica de su restauración.

- Asegurar el registro de las actividades realizadas por el personal operativo, para su posterior revisión.
- Implementar los controles de seguridad definidos (software malicioso y accesos no autorizados).
- Definir e implementar procedimientos para la administración de medios informáticos de almacenamiento y para la eliminación segura de los mismos.
- Participar en el tratamiento de los incidentes de seguridad, de acuerdo con los procedimientos establecidos.

Seguridad de la Información junto con **Sistemas** y **Legales** evaluarán los contratos y acuerdos con terceros para garantizar la incorporación de consideraciones relativas a la seguridad de la información involucrada en la gestión de los productos o servicios prestados.

8.1. Procedimientos y Responsabilidades Operativas

8.1.1. Control de Cambios en las Operaciones

Se definirán procedimientos para el control de los cambios en el ambiente operativo y de comunicaciones. Todo cambio deberá ser evaluado previamente en aspectos técnicos y de seguridad.

Seguridad de la Información controlará que los cambios en los componentes operativos y de comunicaciones no afecten la seguridad de estos ni de la información que soportan. **Sistemas** evaluará el posible impacto operativo de los cambios previstos y verificará su correcta implementación.

Se retendrá un registro de auditoría que contenga toda la información relevante de cada cambio implementado.

8.1.2. Procedimientos de Manejo de Incidentes

Se establecerán funciones y procedimientos de manejo de incidentes garantizando una respuesta rápida, eficaz y sistemática a los incidentes relativos a seguridad de la información.

8.1.3. Separación entre Instalaciones de Desarrollo e Instalaciones Operativas

Los ambientes de desarrollo, prueba y operaciones, estarán separados y se definirán y documentarán las reglas para la transferencia de software desde el estado de desarrollo hacia el estado operativo.

El personal de desarrollo no tendrá acceso al ambiente operativo. De ser extrema dicha necesidad, se establecerá un procedimiento de emergencia para la autorización, documentación y registro de dichos accesos.

8.2. Protección Contra Software Malicioso

Seguridad de la Información definirá controles de detección y prevención para la protección contra software malicioso. **Sistemas** implementarán dichos controles.

Seguridad de la Información desarrollará procedimientos adecuados de concientización de usuarios en materia de seguridad, controles de acceso al sistema y administración de cambios.

8.3. Mantenimiento

8.3.1. Resguardo de la Información

Sistemas y **Seguridad de la Información** junto a los **Propietarios de Información** determinarán los requerimientos para resguardar cada software o dato en función de su criticidad.

Sistemas dispondrá y controlará la realización de dichas copias, así como la prueba periódica de su restauración. Para esto se deberá contar con instalaciones de resguardo que garanticen la disponibilidad de toda la información y del software crítico de la Organización.

8.3.2. Registro de Actividades del Personal Operativo

Sistemas asegurará el registro de las actividades realizadas en los sistemas.

8.4. Administración y Seguridad de los Medios de Almacenamiento

8.4.1. Administración de Medios Informáticos Removibles

Sistemas con la asistencia de **Seguridad de la Información**, implementará procedimientos para la administración y auditoría de medios informáticos removibles.

8.4.2. Eliminación de Medios de Información

Sistemas junto con **Seguridad de la Información** definirá procedimientos para la eliminación segura de los medios de información respetando la normativa vigente.

8.5. Intercambios de Información y Software

8.5.1. Seguridad del Correo Electrónico

Seguridad de la Información definirá:

- controles para reducir los riesgos de incidentes de seguridad en el correo electrónico
- normas y procedimientos claros con respecto al uso del correo electrónico.

8.5.2. Sistemas de Acceso Público

Se tomarán recaudos para la protección de la integridad de la información publicada electrónicamente, a fin de prevenir la modificación no autorizada que podría dañar la reputación de la Organización.

Se implementará un proceso de autorización formal antes de que la información se ponga a disposición del público, estableciéndose en todos los casos los encargados de dicha aprobación.

9. Control de Accesos

El acceso por medio de un sistema de restricciones y excepciones a la información es la base de todo sistema de seguridad de la información. Para impedir el acceso no autorizado a los sistemas de información se deben implementar procedimientos formales para controlar la asignación de derechos de acceso a los sistemas de información, bases de datos y servicios de información, y estos deben estar claramente documentados, comunicados y controlados en cuanto a su cumplimiento.

Los procedimientos comprenden todas las etapas del ciclo de vida de los accesos de los usuarios de todos los niveles, desde el registro inicial de nuevos usuarios hasta la privación final de derechos de los usuarios que ya no requieren el acceso.

La cooperación de los usuarios es esencial para la eficacia de la seguridad, por lo tanto, es necesario concientizar a los mismos acerca de sus responsabilidades por el mantenimiento de controles de acceso eficaces, en particular aquellos relacionados con el uso de contraseñas y la seguridad del equipamiento.

Objetivo

Impedir el acceso no autorizado a los sistemas de información, bases de datos y servicios de información.

Implementar seguridad en los accesos de usuarios por medio de técnicas de autenticación y autorización.

Controlar la seguridad en la conexión entre la red de la Organización y otras redes públicas o privadas.

Registrar y revisar eventos y actividades críticas llevadas a cabo por los usuarios en los sistemas.

Concientizar a los usuarios respecto de su responsabilidad frente a la utilización de contraseñas y equipos.

Garantizar la seguridad de la información cuando se utiliza computación móvil.

Alcance

La Política definida en este documento se aplica a todas las formas de acceso de aquellos a quienes se les haya otorgado permisos sobre los sistemas de información, bases de datos o servicios de información de la Organización, cualquiera sea la función que desempeñe.

Asimismo, se aplica al personal técnico que define, instala, administra y mantiene los permisos de acceso y las conexiones de red, y a los que administran su seguridad.

Responsabilidad

Seguridad de la Información estará a cargo de:

- Definir normas y procedimientos para la gestión de accesos a todos los sistemas, bases de datos y servicios de información.
- Definir pautas de utilización de Internet para todos los usuarios y controlar el uso de esta mediante reportes de actividad de los mismos.
- Controlar la asignación de privilegios a usuarios.
- Verificar el cumplimiento de las pautas establecidas.
- Concientizar a los usuarios sobre el uso apropiado de contraseñas y de equipos de trabajo.
- Implementar procedimientos para la activación y desactivación de derechos de acceso a las redes.
- Otorgar acceso a los servicios y recursos de red, únicamente de acuerdo con el pedido formal correspondiente.

Los Propietarios de la Información estarán encargados de:

- Evaluar los riesgos a los cuales se expone la información con el objeto de:
 - Determinar los controles de accesos, autenticación y utilización a ser implementados en cada caso.
 - Definir los eventos y actividades de usuarios a ser registrados en los sistemas de procesamiento de su incumbencia y la periodicidad de revisión de los mismos.
- Aprobar y solicitar la asignación de privilegios a usuarios.
- Llevar a cabo un proceso formal y periódico de revisión de los derechos de acceso a la información.

Los Propietarios de la Información junto con **Seguridad de la Información** definirán un cronograma de depuración de registros en línea en función a normas vigentes y a sus propias necesidades.

Cada sector autorizará el acceso de los usuarios a su cargo a los servicios y recursos de red y a Internet.

Sistemas cumplirá las siguientes funciones:

- Analizar e implementar los métodos de autenticación y control de acceso definidos en los sistemas, bases de datos y servicios.
- Realizar una adecuada subdivisión de la red e implementar el control de puertos.
- Definir e implementar los registros de eventos y actividades correspondientes a sistemas operativos y otras plataformas de procesamiento.
- Analizar las medidas a ser implementadas para efectivizar el control de acceso a Internet de los usuarios.
- Efectuar un control de los registros de auditoría generados por los sistemas operativos y de comunicaciones.

9.1. Requerimientos para el Control de Acceso

9.1.1. Política de Control de Accesos

En la aplicación de controles de acceso, se contemplarán los siguientes aspectos:

- Identificar los requerimientos de seguridad de cada una de las aplicaciones.
- Identificar toda la información relacionada con las aplicaciones.

9.1.2. Reglas de Control de Acceso

Las reglas de control de acceso especificadas deberán:

- Indicar expresamente si las reglas son obligatorias u optativas
- Establecer reglas sobre la premisa "Todo debe estar prohibido a menos que se permita expresamente".
- Controlar los cambios en los permisos de usuario.

9.2. Administración de Accesos de Usuarios

Con el objetivo de impedir el acceso no autorizado a la información se implementarán procedimientos formales para controlar la asignación de derechos de acceso a los sistemas, datos y servicios de información.

9.2.1. Registración de Usuarios

Seguridad de la Información definirá un procedimiento formal de registro de usuarios para otorgar y revocar el acceso a todos los sistemas, bases de datos y servicios de información multiusuario, el cual debe comprender:

- Utilizar identificadores de usuario únicos. El uso de identificadores grupales sólo debe ser permitido cuando sean convenientes para el trabajo a desarrollar debido a razones operativas.
- Verificar que el usuario tiene autorización del Propietario de la Información para el uso del sistema, base de datos o servicio de información.
- Verificar que el nivel de acceso otorgado es adecuado para el propósito de la función del usuario.
- Requerir que los usuarios firmen declaraciones señalando que comprenden y aceptan las condiciones para el acceso.
- Cancelar inmediatamente los derechos de acceso de los usuarios que cambiaron sus tareas, o de aquellos a los que se les revocó la autorización o se desvincularon de la Organización.
- Efectuar revisiones periódicas con el objeto de:
 - Cancelar identificadores y cuentas de usuario redundantes
 - Inhabilitar y/o eliminar cuentas inactivas por un periodo determinado.

9.2.2. Administración de Contraseñas de Usuario

La asignación de contraseñas se controlará a través de un proceso de administración formal, mediante el cual deben respetarse los siguientes pasos:

- Requerir que los usuarios firmen una declaración por la cual se comprometen a mantener sus contraseñas personales en secreto. Garantizar que los usuarios cambien las contraseñas iniciales.
- Almacenar las contraseñas sólo en sistemas informáticos protegidos.
- Configurar los sistemas de tal manera que permitan únicamente la utilización de contraseñas robustas.

9.2.3. Administración de Contraseñas críticas

Seguridad de la Información junto con **Sistemas** definirán los procedimientos para la administración de las contraseñas críticas.

9.3. Responsabilidades del Usuario

9.3.1. Uso de Contraseñas

Los usuarios deben seguir buenas prácticas de seguridad en la selección y uso de contraseñas.

Las contraseñas constituyen un medio de validación y autenticación de la identidad de un usuario, y consecuentemente un medio para establecer derechos de acceso a las instalaciones o servicios de procesamiento de información.

Los usuarios deben cumplir las siguientes directivas:

- Mantener las contraseñas en secreto.
- Cambiar la contraseña siempre que exista un posible indicio de compromiso del sistema.
- Seleccionar contraseñas de calidad que:
 - Sean fáciles de recordar.

- No estén basadas en algún dato que otra persona pueda adivinar u obtener fácilmente.
- Cambiar las contraseñas cada vez que el sistema se lo solicite.

9.4. Control de Acceso a la Red

9.4.1. Política de Utilización de los Servicios de Red

Las conexiones no seguras a los servicios de red pueden afectar a toda la red de la Organización, por lo tanto, se controlará el acceso a los servicios de red tanto internos como externos.

Seguridad de la Información tendrá a cargo el otorgamiento del acceso a los servicios y recursos de red, únicamente de acuerdo con el pedido formal.

9.4.2. Subdivisión de Redes

Para controlar la seguridad en redes, se deberán dividir en dominios lógicos separados. Para esto se definirán y documentarán los perímetros de seguridad que sean convenientes.

9.4.3. Acceso a Internet

El acceso a Internet será utilizado con propósitos autorizados o con el destino por el cual fue provisto. Para todos los usuarios está prohibido el acceso a contenidos considerados inapropiados al propósito del negocio de la Organización. A tal fin se considerarán inapropiados:

- Páginas de descargas.
- Página de hacking.
- Páginas de Juegos.
- Páginas con contenido de violencia, discriminación, odio racial, étnico o religioso.
- Páginas con contenido obsceno y/o pornográfico

Adicionalmente, se implementará un registro de los accesos de los usuarios a Internet, con el objeto de realizar revisiones de los accesos efectuados o analizar casos particulares.

Dicho control deberá ser comunicado a los usuarios.

Seguridad de la Información junto con **Sistemas** analizarán las medidas a ser implementadas para efectivizar dicho control.

9.4.8. Seguridad de los Servicios de Red

Seguridad de la Información junto con **Sistemas** definirán las pautas para garantizar la seguridad de los servicios de red de la Organización, tanto públicos como privados.

Para ello se tendrán en cuenta las siguientes directivas:

- Mantener instalados y habilitados sólo aquellos servicios que sean utilizados.
- Controlar el acceso lógico a los servicios, tanto a su uso como a su administración.
- Configurar cada servicio de manera segura, evitando las vulnerabilidades que pudieran presentar.
- Instalar periódicamente las actualizaciones de seguridad.

9.5. Control de Acceso al Sistema Operativo

9.5.1. Procedimientos de Conexión de equipos de usuario

El acceso a los servicios de información sólo será posible a través de un proceso de conexión seguro. El procedimiento de conexión en un sistema informático será diseñado para minimizar la oportunidad de acceso no autorizado.

Este procedimiento, por lo tanto, debe divulgar la mínima información posible acerca del sistema, a fin de evitar proveer de asistencia innecesaria a un usuario no autorizado.

9.5.2. Identificación y Autenticación de los Usuarios

Todos los usuarios tendrán un identificador único (ID de usuario) para su uso personal exclusivo, de manera que las actividades puedan rastrearse con posterioridad. Los identificadores de usuario no darán ningún indicio del nivel de privilegio otorgado.

En circunstancias excepcionales, cuando existe un claro beneficio para la Organización, podrá utilizarse un identificador compartido para un grupo de usuarios o una tarea específica. Para casos de esta índole, se documentará la justificación y su aprobación.

9.5.3. Limitación del Horario de Conexión

La limitación del periodo durante el cual se permiten las conexiones de los equipos a los servicios informáticos reduce el espectro de oportunidades para el acceso no autorizado.

9.6. Monitoreo del Acceso y Uso de los Sistemas

9.6.1. Registro de Eventos

Se generarán registros de auditoría que contengan excepciones y otros eventos relativos a la seguridad.

Los registros de auditoría deberán incluir:

- Identificación del usuario.
- Fecha y hora de inicio y terminación.
- Registros de intentos exitosos y fallidos de acceso al sistema.
- Registros de intentos exitosos y fallidos de acceso a datos y otros recursos.

9.7. Computación Móvil y Trabajo Remoto

9.7.1. Computación Móvil y Trabajo remoto

Cuando se utilicen dispositivos informáticos móviles propiedad de La empresa y/o asignados por ésta y/o validados o autorizados para tal fin, se deberá tener especial cuidado en garantizar que no se comprometa la información de la Organización, con lo cual cada usuario garantizará que ningún tercero acceda a dichos dispositivos bajo su responsabilidad, evitando así que se vulneren los objetivos y propósitos perseguidos por esta normativa y que hacen a la debida confidencialidad y resguardo de la información.

Se desarrollarán procedimientos adecuados para estos dispositivos, que abarquen los siguientes conceptos:

- La protección física necesaria

- El acceso seguro a los dispositivos
- La utilización de los dispositivos en lugares públicos.
- El acceso a los sistemas de información y servicios de la Organización a través de dichos dispositivos.
- Las técnicas criptográficas para utilizar.
- Los mecanismos de resguardo de la información contenida en los dispositivos.
- La protección contra software malicioso.

10. Desarrollo y Mantenimiento de Sistemas

El desarrollo y mantenimiento de las aplicaciones es un punto crítico de la seguridad.

Durante el análisis y diseño de los procesos que soportan estas aplicaciones se deben identificar, documentar y aprobar los requerimientos de seguridad a incorporar durante las etapas de desarrollo e implementación.

Asimismo, es necesaria una adecuada administración de la infraestructura de base, Sistemas Operativos y Software de Base, en las distintas plataformas, para asegurar una correcta implementación de la seguridad.

Objetivo

Asegurar la inclusión de controles de seguridad en el desarrollo de los sistemas de información.

Definir y documentar las normas y procedimientos de seguridad que se aplicarán durante el ciclo de vida de los aplicativos y en la infraestructura de base en la cual se apoyan.

Alcance

Esta Política se aplica a todos los sistemas informáticos, tanto desarrollos propios o de terceros, y a todos los Sistemas Operativos y/o Software de Base que integren cualquiera de los ambientes administrados por la Organización en donde residan los desarrollos mencionados.

Responsabilidad

Seguridad de la Información junto con el **Propietario de la Información y Sistemas**, definirán los controles a ser implementados en los sistemas desarrollados internamente o por terceros.

Seguridad de la Información verificará el cumplimiento de los requerimientos de seguridad establecidos para el desarrollo y mantenimiento de sistemas.

Sistemas propondrá para su aprobación, la asignación de funciones de “*Implementador*” y “*Administrador de programas fuentes*” al personal de su área que considere adecuado, cuyas responsabilidades se detallan en el presente capítulo. Asimismo, verificará el cumplimiento de las definiciones establecidas sobre los controles y las medidas de seguridad a ser incorporadas a los sistemas.

10.1. Análisis y Especificaciones de los Requerimientos de Seguridad

Esta Política se implementa para incorporar seguridad a los sistemas de información (propios o de terceros) y a las mejoras o actualizaciones que se les incorporen.

Para ello, se definirá un procedimiento de modo de incorporar los requerimientos de seguridad durante las etapas de análisis y diseño de sistemas.

10.2. Controles Criptográficos

Cuando sea necesario, se utilizarán sistemas y técnicas criptográficas para la protección de la información, con el fin de asegurar una adecuada protección de su confidencialidad e integridad.

10.3. Seguridad de los Archivos del Sistema

Se garantizará que los desarrollos y actividades de soporte a los sistemas se lleven a cabo de manera segura, controlando el acceso a los archivos de este.

10.3.1. Control del Software Operativo

Se definen los siguientes controles a realizar durante la implementación del software en producción, a fin de minimizar el riesgo de alteración de los sistemas.

- Ningún programador o analista de desarrollo y mantenimiento de aplicaciones podrá acceder a los ambientes de producción.
- **Sistemas** propondrá para su aprobación la asignación de la función de “*Implementador*” al personal de su área que considere adecuado, quien tendrá como funciones principales:
 - Coordinar la implementación de modificaciones o nuevos programas en el ambiente de Producción.
 - Asegurar que los sistemas aplicativos en uso, en el ambiente de Producción, sean los autorizados y aprobados de acuerdo a las normas y procedimientos vigentes.
 - Instalar las modificaciones, controlando previamente la recepción de la prueba aprobada por parte del Analista Responsable y del usuario final.

10.3.2. Protección de los Datos de Prueba del Sistema

Las pruebas de los sistemas se efectuarán sobre datos extraídos del ambiente operativo. Para proteger los datos de prueba se establecerán normas y procedimientos que contemplen lo siguiente:

- Prohibir el uso de bases de datos operativas. En caso contrario se deben despersonalizar los datos antes de su uso.
- Solicitar autorización formal para realizar una copia de la base operativa como base de prueba, llevando registro de tal autorización.
- Eliminar inmediatamente, una vez completadas las pruebas, la información operativa utilizada.

10.3.3. Control de Cambios a Datos Operativos

La modificación, actualización o eliminación de los datos operativos serán realizadas a través de los sistemas que procesan dichos datos y de acuerdo con el esquema de control de accesos implementado en los mismos. Una modificación por fuera de los sistemas a un dato, almacenado ya sea en un archivo o base de datos, podría poner en riesgo la integridad de la información.

Los casos en los que no fuera posible la aplicación de la precedente política, se considerarán como excepciones. **Seguridad de la Información** definirá procedimientos para la gestión de dichas excepciones que contemplarán lo siguiente:

- Se generará una solicitud formal para la realización de la modificación, actualización o eliminación del dato.
- El **Propietario de la Información** afectada y **Seguridad de la Información** aprobarán la ejecución del cambio evaluando las razones por las cuales se solicita.

10.3.4. Control de Acceso a Programas Fuentes

Para reducir la probabilidad de alteración de programas fuentes, **Sistemas** propondrá para su aprobación la función de “*Administrador de programas fuentes*” al personal de su área que considere adecuado, quien tendrá en custodia los programas fuentes y deberá:

- Proveer los programas fuentes solicitados para su modificación, manteniendo en todo momento la correlación programa fuente / ejecutable.
- Llevar un registro actualizado de todos los programas fuentes en uso.
- Prohibir el acceso a todo operador y/o usuario de aplicaciones a los ambientes y a las herramientas que permitan la generación y/o manipulación de los programas fuentes.

10.4. Seguridad de los Procesos de Desarrollo y Soporte

Esta Política provee seguridad al software y a la información del sistema de aplicación, por lo tanto, se controlarán los entornos y el soporte dado a los mismos.

10.4.1. Procedimiento de Control de Cambios

A fin de minimizar los riesgos de alteración de los sistemas de información, se implementarán controles durante la implementación de cambios imponiendo el cumplimiento de procedimientos formales. Éstos garantizarán que se cumplan los procedimientos de seguridad y control, respetando la división de funciones.

Para ello se establecerá un procedimiento que incluya las siguientes consideraciones:

- Identificar todos los elementos que requieren modificaciones (software, bases de datos, hardware).
- Obtener aprobación formal por parte de **Sistemas** para las tareas detalladas, antes que comiencen las tareas.
- Solicitar la revisión **Seguridad de la Información** para garantizar que no se violen los requerimientos de seguridad que debe cumplir el software.
- Efectuar las actividades relativas al cambio en el ambiente de desarrollo.
- Actualizar la documentación para cada cambio implementado, tanto de los manuales de usuario como de la documentación operativa.
- Mantener un control de versiones para todas las actualizaciones de software.
- Garantizar que la implementación se llevará a cabo minimizando la discontinuidad de las actividades y sin alterar los procesos involucrados.
- Garantizar que sea el “*Implementador*” quien efectúe el pasaje de los objetos modificados al ambiente operativo.

10.4.2. Revisión Técnica de los Cambios en el Sistema Operativo

Toda vez que sea necesario realizar un cambio en el Sistema Operativo, los sistemas serán revisados para asegurar que no se produzca un impacto en su funcionamiento o seguridad.

10.4.3. Desarrollo Externo de Software

Para el caso que se considere la tercerización del desarrollo de software, se establecerán normas y procedimientos que contemplen los siguientes puntos:

- Acuerdos de licencias, propiedad de código y derechos conferidos.
- Acuerdos de confidencialidad.
- Acceso a entornos de desarrollo, prueba y producción.
- Requerimientos contractuales con respecto a la calidad del código y la existencia de garantías.
- Procedimientos de certificación de la calidad y precisión del trabajo llevado a cabo por el proveedor.
- Acuerdos de custodia de los programas fuentes del software (y cualquier otra información requerida) en caso de quiebra de la tercera parte.

11. Administración de la Continuidad de las Actividades de la Organización

La administración de la continuidad de las actividades es un proceso crítico que debe involucrar a todos los niveles de la Organización.

El desarrollo e implementación de planes de contingencia es una herramienta básica para garantizar que las actividades de la Organización puedan restablecerse dentro de los plazos requeridos.

Dichos planes deben mantenerse actualizados y transformarse en una parte integral del resto de los procesos de administración y gestión.

Objetivo

Minimizar los efectos de las posibles interrupciones de las actividades normales de la Organización (sean éstas resultado de desastres naturales, accidentes, fallas en el equipamiento u otros hechos) y proteger los procesos críticos mediante una combinación de controles preventivos y acciones de recuperación.

Analizar las consecuencias de la interrupción del servicio y tomar las medidas correspondientes para la prevención de hechos similares en el futuro.

Asegurar la coordinación con el personal de la Organización y los contactos externos que participarán en las estrategias de planificación de contingencias. Asignar funciones para cada actividad definida.

Alcance

Esta Política se aplica a todos los procesos críticos identificados de la Organización.

Responsabilidad

Seguridad de la Información participará en la definición, documentación y actualización de los planes de contingencia.

Los **Propietarios de la Información** y **Seguridad de la Información** cumplirán las siguientes funciones:

- Identificar las amenazas que puedan ocasionar interrupciones de los procesos y/o las actividades de la Organización.

- Evaluar los riesgos para determinar el impacto de dichas interrupciones.
- Elaborar los planes de contingencia necesarios para garantizar la continuidad de las actividades del Organización.
- Identificar y priorizar los procesos críticos de las actividades de la Organización.
- Asegurar que todos los integrantes de la Organización comprendan los riesgos que la misma enfrenta, en términos de probabilidad de ocurrencia e impacto de posibles amenazas, así como los efectos que una interrupción puede tener en la actividad de la Organización.
- Coordinar actualizaciones periódicas de los planes y procesos implementados.

11.1. Continuidad de las Actividades y Análisis de los Impactos

Con el fin de establecer un Plan de Continuidad de las Actividades de la Organización se deben contemplar los siguientes puntos:

- Identificar los eventos (amenazas) que puedan ocasionar interrupciones en los procesos de las actividades, por ejemplo, fallas en el equipamiento, interrupción del suministro de energía eléctrica, inundación e incendio, desastres naturales, destrucción edilicia, etc.
- Evaluar los riesgos para determinar el impacto de dichas interrupciones, tanto en términos de magnitud de daño como del período de recuperación. Dicha evaluación debe identificar los recursos críticos, los impactos producidos por una interrupción, los tiempos de interrupción aceptables o permitidos, y debe especificar las prioridades de recuperación.
- Identificar los controles preventivos, como por ejemplo sistemas de supresión de fuego, detectores de humo y fuego, contenedores resistentes al calor, etc.

Esta actividad será llevada a cabo con la activa participación de los **Propietarios de la información y Seguridad de la Información**.

11.2. Elaboración e Implementación de los Planes de Continuidad

Los **Propietarios de la información y Seguridad de la Información**, elaborarán los planes de contingencia necesarios para garantizar la continuidad de las actividades de la Organización.

El proceso de planificación de la continuidad de las actividades considerará los siguientes puntos:

- Analizar los posibles escenarios de contingencia y definir las acciones correctivas a implementar en cada caso.
- Implementar procedimientos de emergencia para permitir la recuperación y restablecimiento en los plazos requeridos. Se debe dedicar especial atención a la evaluación de las dependencias de actividades externas y a los contratos vigentes.
- Documentar los procedimientos y procesos acordados.
- Probar y actualizar los planes periódicamente.

12. Cumplimiento

El diseño, operación, uso y administración de los sistemas de información están regulados por disposiciones legales y contractuales.

Objetivo

Cumplir con las disposiciones normativas y contractuales a fin de evitar sanciones administrativas a la Organización.

Garantizar que los sistemas cumplan con la política, normas y procedimientos de seguridad de la Organización.

Alcance

Esta Política se aplica a todo el personal de la Organización.

Asimismo, se aplica a los sistemas de información, normas, procedimientos, documentación y plataformas técnicas de la Organización y a las auditorías efectuadas sobre los mismos.

Responsabilidad

Seguridad de la Información verificará periódicamente que los sistemas de información cumplan la política, normas y procedimientos de seguridad establecidos.

Sistemas verificará que sólo se instalen productos con licencia y software autorizado.

Todos los empleados comprenderán, darán a conocer y cumplirán la presente Política.

12.1. Cumplimiento de Requisitos Legales

12.1.1. Derecho de Propiedad Intelectual del Software

El software es considerado una obra intelectual que goza de la protección de la Ley 11.723 de Propiedad Intelectual.

Los productos de software se suministran normalmente bajo acuerdos de licencia que suelen limitar el uso de los productos al equipamiento específico y su copia a la creación de copias de resguardo solamente.

Seguridad de la Información, con la asistencia de **Sistemas** verificará que sólo se instalen productos con licencia y software autorizado.

12.1.2. Prevención del Uso Inadecuado de los Recursos de Procesamiento de Información

Los recursos de procesamiento de información de la Organización se suministran con un propósito determinado. Toda utilización de estos recursos con propósitos no autorizados o ajenos al destino por el cual fueron provistos debe ser considerada como uso indebido.

Todos los empleados deben conocer el alcance preciso del uso adecuado de los recursos informáticos y deben respetarlo.

12.2. Cumplimiento de la Política de Seguridad

Cada Sector, velará por la correcta implementación y cumplimiento de las normas y procedimientos de seguridad establecidos, dentro de su área de responsabilidad, dando a conocer y reportando a **Seguridad de la Información** toda anomalía o incumplimiento que detecte.